BOTIUM TOYS

Security Controls & Compliance Review

Portfolio case study · fictional organization · document-based assessment

8/10	5 / 14	7 / 14	3 / 12
Scenario risk	**Controls**	**Controls**	**Compliance**
High	Implemented	Not implemented	Implemented

PORTFOLIO NOTE

This is an educational case study based on the Botium Toys materials from the Google Cybersecurity Certificate. I did not test a live environment, validate configurations, or perform a formal PCI DSS, GDPR, or SOC assessment.

Focus

Access control / data confidentiality / recovery / monitoring

01 Executive Summary

Botium Toys already has a useful security baseline. A firewall is filtering traffic, antivirus is monitored, data-integrity controls are in place, and the offices, storefront, and warehouse have locks, CCTV, and fire protection. The problem is that these controls are uneven. The company is stronger at protecting the perimeter and physical location than it is at deciding who should see sensitive data, protecting that data once it is stored, and recovering when something goes wrong.

The biggest concern is access. All employees can reach internally stored data, while least privilege and separation of duties are not implemented. That same weakness shows up again in the PCI DSS and SOC-related checks because customer, cardholder, and PII/SPII data are in scope. Encryption is also missing, so the confidentiality gap is not only about who can access the data, but how well the data itself is protected.

Recovery is the other major weakness. There are no backups of critical data and no disaster recovery plan. Detection is also incomplete: the firewall and antivirus provide a baseline, but there is no IDS, and legacy systems are monitored without a regular schedule or clear intervention procedure.

I kept the scenario's 8/10 risk score. My first priorities would be to restrict access to sensitive information, introduce encryption, establish backups and a recovery plan, strengthen password controls, and improve monitoring. The controls that already work should be kept and built around rather than replaced for the sake of it.

What the source material already gets right

- Firewall rules are described as appropriately defined and active.
- Antivirus is installed and monitored regularly.
- Data-integrity controls are in place.
- A 72-hour breach-notification plan exists for E.U. customers.
- Privacy procedures are documented and enforced among relevant staff.
- Physical security includes locks, CCTV, and fire detection/prevention.

02 Scope & Method

The assessment covers the security program described in the case: employee devices, the internal network, business systems, stored data, ecommerce and inventory services, legacy systems, and the physical location. The source material also includes assets such as storefront inventory and on-premises equipment because their loss or disruption can affect business continuity.

Assessment goals

- Identify which controls are already in place and which are missing or incomplete.
- Connect the control gaps to the PCI DSS, GDPR, and SOC-related practices used in the exercise.
- Turn the checklist into a practical remediation order that a stakeholder could act on.

How I scored the controls

The original exercise is mostly Yes/No. For the portfolio version I added a third status, Partially implemented, where a binary answer would hide useful context. Two examples are the password policy, which exists but is weak, and legacy-system monitoring, which exists but is not scheduled or backed by a clear intervention process.

Priorities are my analyst layer, not scores from the course material. They are there to show which gaps I would address first based on the evidence in the scenario. I did not add technical facts that were not in the supplied documents.

03 Risk Overview

8/10	High	High	Partial
Overall risk	**Data exposure**	**Recovery gap**	**Detection**
Source rating	Access + encryption	No backup / DR	Firewall + AV, no IDS

What is driving the risk

- Everyone can access internally stored data; least privilege and separation of duties are missing.
- Cardholder information is not protected with encryption in the scenario.
- Critical data have no backup, and there is no disaster recovery plan.
- An IDS is not installed, leaving a gap in network-level detection.
- Password requirements are weak and are not centrally enforced.
- Legacy systems are maintained manually, but the schedule and intervention process are unclear.

The scenario describes the impact of losing an individual asset as medium, largely because the asset picture is incomplete. The broader exposure is higher: sensitive information may be accessible too widely, and missing recovery controls could turn a security incident or system failure into a longer business interruption.

04 Control Categories & Quick Glossary

I kept the same terminology used in the supplied control-categories reference. Category tells us where a control sits; type tells us what the control is meant to do. Those are related ideas, but they are not the same thing.

CATEGORY	PLAIN-LANGUAGE MEANING	EXAMPLES IN THIS CASE
Administrative / Managerial	Policies, responsibilities, and management practices that shape how people handle security and data.	Least privilege, password policy, separation of duties, disaster recovery
Technical	Technology used to protect systems, networks, accounts, or data.	Firewall, IDS, encryption, backups, antivirus, password management
Physical	Measures that protect buildings, equipment, and other physical assets from unauthorized access or damage.	Locks, CCTV, fire detection/prevention

TYPE	WHAT IT IS MEANT TO DO	EXAMPLE
Preventative	Reduce the chance of an incident happening in the first place.	Least privilege, firewall, password policy
Detective	Show that suspicious activity or an incident is happening or has happened.	IDS, CCTV
Corrective	Help restore data, systems, or operations after an event.	Backups, disaster recovery
Deterrent	Discourage an attack or make an asset less attractive to target.	Locks; the course reference also classifies encryption here

Note: some real-world security teams may classify individual controls differently depending on context. This report keeps the course reference's labels so the case study stays consistent with the material it is based on.

05 Controls Assessment

The questions are written to include the intent of each control, so the table can stand on its own. Evidence and recommendations stay close to the wording of the case rather than assuming details that were never provided.

CONTROL	CATEGORY / TYPE	ASSESSMENT QUESTION	STATUS	EVIDENCE	RECOMMENDED ACTION	PRIORITY
Least Privilege	Administrative / Preventative	Can employees reach only the data they actually need for their jobs, especially customer, payment, and other sensitive data?	**Not implemented**	All employees have access to internally stored data and may be able to reach cardholder data and PII/SPII.	Limit access by role and business need, then review permissions regularly.	**Critical**
Disaster recovery plans	Administrative / Corrective	If a major system or dataset is lost, is there a written plan for restoring critical operations?	**Not implemented**	No disaster recovery plan is in place.	Document recovery responsibilities and procedures for critical systems and data.	**Critical**
Password policies	Administrative / Preventative	Does the password policy set reasonable minimum requirements, and is it actually enforced?	**Partially implemented**	A policy exists, but the scenario describes its requirements as nominal and below the stated minimum expectations.	Strengthen the policy and enforce it through centralized password management.	**High**
Separation of duties	Administrative / Preventative	Are sensitive responsibilities split so that one person does not control incompatible tasks?	**Not implemented**	The control is not in place. The exemplar also notes that the CEO manages day-to-day operations and payroll.	Separate incompatible duties and add independent approval where appropriate.	**High**
Firewall	Technical / Preventative	Is unwanted network traffic filtered using an appropriately defined rule set?	**Implemented**	The firewall blocks traffic based on an appropriately defined set of security rules.	Keep the firewall in place and review the rules as the environment changes.	**Maintain**
Intrusion detection system (IDS)	Technical / Detective	Is there a network detection control that can flag anomalous or potentially malicious activity?	**Not implemented**	The IT department has not installed an IDS.	Deploy an IDS and define who reviews, escalates, and documents alerts.	**High**
Backups	Technical / Corrective	Are critical data backed up so they can be restored after loss, corruption, or an incident?	**Not implemented**	The company does not have backups of critical data.	Create regular backups and document a restoration process.	**Critical**
Antivirus software	Technical / Corrective	Is antivirus installed and monitored on the systems covered by the scenario?	**Implemented**	Antivirus is installed and monitored regularly by the IT department.	Maintain monitoring and keep the control operational.	**Maintain**
Legacy system monitoring	Technical / Preventative	Are legacy systems checked on a regular schedule, with a clear process for intervention when a problem is found?	**Partially implemented**	Legacy systems are monitored and maintained, but there is no regular schedule and intervention methods are unclear.	Set a maintenance schedule and document the intervention process.	**High**
Encryption	Technical / Deterrent*	Is sensitive and cardholder information protected with encryption as described in the case requirements?	**Not implemented**	Encryption is not currently used for customers' credit-card information.	Introduce encryption for sensitive and cardholder data at the relevant touchpoints.	**Critical**
Password management system	Technical / Preventative	Is there a centralized system that supports and enforces the password policy?	**Not implemented**	No centralized password management system is in place.	Implement centralized password management that enforces the approved policy.	**High**

CONTROL	CATEGORY / TYPE	ASSESSMENT QUESTION	STATUS	EVIDENCE	RECOMMENDED ACTION	PRIORITY
Locks	Physical / Deterrent + Preventative	Are offices, the storefront, and the warehouse protected against unauthorized physical entry?	**Implemented**	The physical location has sufficient locks.	Maintain the locks and include them in routine physical-security checks.	**Maintain**
CCTV surveillance	Physical / Preventative + Detective	Is CCTV installed and functioning at the physical location?	**Implemented**	CCTV is installed and functioning.	Maintain coverage and verify that the system remains operational.	**Maintain**
Fire detection / prevention	Physical / Detective + Preventative	Are fire detection and prevention systems functioning at the physical location?	**Implemented**	The location has functioning fire detection and prevention systems.	Maintain and test the existing systems.	**Maintain**

** Encryption is shown as Deterrent because that is how it is classified in the supplied course reference.*

06 Compliance Assessment

This section checks only the practices listed in the exercise. It should not be read as a formal certification or legal opinion. The wording below is intentionally practical: each question says what I looked for, and the evidence explains why the status was chosen.

AREA	FOCUS	ASSESSMENT QUESTION	STATUS	EVIDENCE	RECOMMENDED ACTION	PRIORITY
PCI DSS - Access	Authorized access to cardholder data	Is cardholder information limited to staff who actually need it for their work?	**Not implemented**	All employees have access to internal data, which may include cardholder information.	Apply least privilege and role-based access restrictions to payment data.	**Critical**
PCI DSS - Environment	Secure cardholder-data environment	Are payment data handled in an environment with appropriate access controls and confidentiality protections?	**Not implemented**	Cardholder data are not encrypted, and access to internal data is overly broad.	Restrict access and add encryption around the cardholder-data environment.	**Critical**
PCI DSS - Encryption	Encryption procedures	Are encryption procedures used to protect cardholder data at the relevant storage, processing, and transmission points?	**Not implemented**	The company does not currently use encryption for customers' financial information.	Implement encryption procedures across relevant payment-data touchpoints.	**Critical**
PCI DSS - Passwords	Secure password management	Are password requirements strong enough to reduce account compromise, and are they centrally enforced?	**Partially implemented**	A password policy exists, but it is weak and there is no centralized password management system.	Strengthen password requirements and enforce them centrally.	**High**
GDPR - Data security	Privacy and security of E.U. customer data	Are E.U. customers' personal data kept private and secured using the controls described in the case?	**Not implemented**	The scenario identifies confidentiality gaps, including broad access and no encryption.	Tighten access to personal data and improve confidentiality controls.	**Critical**
GDPR - Breach notification	72-hour notification plan	Is there a documented plan to notify E.U. customers within 72 hours when their data are compromised, as required by the exercise?	**Implemented**	The scenario states that a 72-hour notification plan is in place.	Maintain the process and keep the documentation usable.	**Maintain**
GDPR - Classification	Data inventory and classification	Are data both inventoried and classified so the organization knows what it holds and how sensitive it is?	**Partially implemented**	Assets/data have been listed, but the source says they have not been fully classified.	Complete classification and use it to match controls to data sensitivity.	**High**

AREA	FOCUS	ASSESSMENT QUESTION	STATUS	EVIDENCE	RECOMMENDED ACTION	PRIORITY
GDPR - Privacy process	Privacy policies and procedures	Are privacy policies, procedures, and processes documented and enforced among relevant employees?	**Implemented**	Privacy policies, procedures, and processes have been developed and enforced.	Maintain the process and review it as the environment changes.	**Maintain**
SOC - Access	User access policies	Are access policies established so users receive only the access they need?	**Not implemented**	Least privilege and separation of duties are not in place; all employees can access internally stored data.	Formalize access policy and enforce role-based permissions.	**Critical**
SOC - Confidentiality	PII/SPII confidentiality	Is sensitive personal information kept confidential through appropriate access and data-protection controls?	**Not implemented**	The scenario says encryption is not used and internal access is too broad.	Restrict access and introduce appropriate confidentiality protections.	**Critical**
SOC - Integrity	Data integrity	Are controls in place to keep data consistent, complete, accurate, and validated?	**Implemented**	The source explicitly states that data-integrity controls are in place.	Maintain the control and continue validating it.	**Maintain**
SOC - Availability / authorization	Authorized availability	Is data available to people who are authorized to use it, without giving access to everyone?	**Not implemented**	Data are available, but authorization is not limited to the people who need access for their jobs.	Limit authorization while preserving availability for legitimate users.	**High**

07 What Stands Out

The checklist has a lot of individual rows, but the same few weaknesses keep appearing. That is useful because it means Botium Toys does not need a different fix for every failed line item. A small number of well-chosen changes would improve several areas at once.

1. Access is the common thread

The absence of least privilege and separation of duties is not an isolated administrative problem. It is the reason the PCI DSS access check fails, and it also drives the SOC-related authorization and confidentiality findings. Fixing access by role would improve several parts of the assessment at the same time.

2. Confidentiality needs more than a policy

Privacy procedures exist, but the technical controls around sensitive data are weaker. Cardholder information is not encrypted, and internal access is too broad. The written process is useful; it just needs stronger technical enforcement around it.

3. Recovery is a real blind spot

No backups and no disaster recovery plan is a risky combination. Backups without a recovery process are hard to use under pressure, and a recovery plan is not much help if the data needed to restore the business do not exist. These two controls should be treated as one recovery problem, not two unrelated checklist items.

4. Some controls exist, but they are informal

The password policy and legacy-system monitoring are both examples of partial implementation. Something is being done, but the control is not strong or repeatable enough yet. Those gaps are usually easier to close than controls that are missing entirely because there is already a starting point.

5. The baseline is worth keeping

The company is not starting from zero. Firewalling, antivirus, data integrity, privacy procedures, physical security, and breach-notification planning already provide a foundation. The remediation plan should preserve those controls while filling the access, confidentiality, recovery, and monitoring gaps.

08 Recommended Order of Work

If I were handing this assessment to an IT manager, I would keep the order simple. Start with the controls that directly reduce exposure of sensitive data and improve recoverability, then move into monitoring and process maturity.

STEP	FOCUS	WHAT I WOULD CHANGE FIRST
1	**Access + confidentiality**	Limit sensitive-data access by role, strengthen password requirements, and begin encryption for cardholder and other sensitive data.
2	**Recovery**	Create regular backups of critical data and write a disaster recovery plan that explains how restoration will actually work.
3	**Detection + identity**	Deploy an IDS, implement centralized password management, and define separation of duties for sensitive responsibilities.
4	**Governance + legacy systems**	Finish data classification, schedule legacy-system maintenance, and document what happens when a legacy-system issue is found.
5	**Recheck**	Repeat the assessment after remediation and confirm that the controls are operating as intended, not just documented.

Status key

STATUS	HOW I USED IT
Implemented	The source shows that the control exists and its stated objective is being met.
Partially implemented	The control exists in some form, but it is weak, informal, incomplete, or inconsistently managed.
Not implemented	The control is absent or the evidence shows that its objective is not being met.

09 Closing Note

Botium Toys has a workable security foundation, but the controls are not balanced. The strongest areas are perimeter, endpoint, physical security, integrity, and parts of privacy process. The weakest areas are authorization, encryption, recovery, and detection. That imbalance explains why the overall risk remains high even though several individual controls are already present.

The useful part of this case study is not the number of failed boxes. It is the way the same root causes appear across different control and compliance areas. Restricting access, protecting sensitive data, and building a real recovery capability would remove several findings at once and make the environment much easier to manage.

Source material used

- Botium Toys: Scope, Goals, and Risk Assessment report
- Controls and Compliance Checklist
- Controls and Compliance Checklist Exemplar
- Control Categories reference
- Audit Scope and Goals reference (used as a reporting and prioritization example)

This portfolio case study stays within the evidence provided by those materials. It is not a formal attestation, certification, or legal determination of compliance.